

Agent Mesh Observatory & Governor

Concept & V0 Product Spec

Updated Pivot: Shadow AI Control Plane (Identity + Policy at the Action Boundary)

Last updated: Dec 25, 2025

1. One-liner

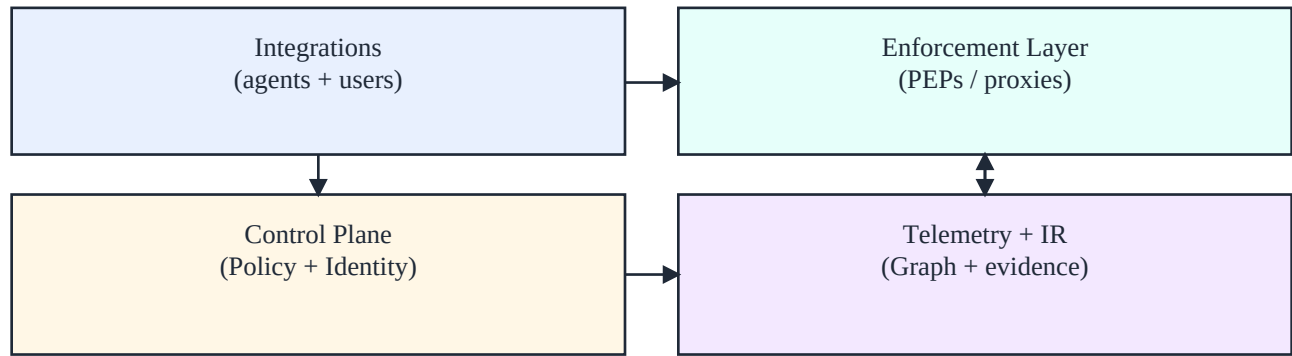
A unified routing, policy enforcement, and forensics layer that brings **shadow AI** (employee GenAI usage) and **sanctioned agents** (tool-enabled automation) under one control plane: identity, least-privilege, approvals, and incident-grade evidence.

2. Problem

- **No visibility:** AI usage is split across browsers, desktop apps, IDE copilots, and internal agent runtimes.
- **No enforceable boundary:** policies live as docs; they don't block risky data uploads or dangerous tool actions.
- **Fragmented governance:** each agent framework and AI tool has its own controls (if any), with no central audit trail.
- **Slow investigations:** when something goes wrong, evidence is scattered and incomplete.

3. Product overview (V0)

- **AI Access Proxy (user path):** route browser/IDE/API traffic for approved GenAI tools; log, classify, and enforce policy.
- **Agent SDK / Proxy (agent path):** wrap tool calls and agent-to-agent calls; enforce decisions at the edge (PEPs).
- **Policy + Identity control plane:** PDP evaluates policy and returns allow/deny/allow-with-constraints with rationale + obligations.
- **Evidence + IR:** immutable-ish decision logs, incident timeline view, and one-click evidence bundle export.



Core idea: route all AI interactions through enforceable policy and produce incident-grade evidence.

4. V0 goals and non-goals

Goals (V0)

- Time-to-first-value: detect shadow AI usage patterns and route to approved tools within days.
- Enforce at least 3 high-impact policies (e.g., block sensitive uploads; restrict domains; constrain SQL reads).
- Single interaction graph that spans: user prompts/uploads, agent tool calls, and downstream systems.
- Audit logs: policy versioning, decision logs, and admin actions.
- IR-ready export: evidence bundle containing timeline + policy context + summaries/hashes.

Non-goals (V0)

- No claim of perfect prompt-injection prevention; focus on enforceable boundaries + containment.
- No "read all your prompts" default; raw content storage is optional and customer-controlled.
- No multi-tenant SaaS hardening for ultra-regulated environments in V0 (start self-hosted or single-tenant).

5. Architecture sketch

5.1 Data plane (enforcement)

- **User traffic PEP:** browser/desktop/IDE routing via forward proxy / secure web gateway integration; optional extension for UX.
- **Agent tool PEP:** SDK wrapper or HTTP proxy that intercepts tool calls (MCP/HTTP/RPC) before execution.
- **Credential broker:** mint short-lived, scoped credentials for high-risk tools (db, tickets, payments, cloud).

5.2 Control plane

- **PDP service:** policy evaluation engine (simple JSON rules first; optional Cedar/OPA compatibility later).
- **Policy store:** versioned policies; change history; CI-friendly policy-as-code workflow.
- **Identity:** SSO users, device identity, workload/service accounts; environment and tenant context.

5.3 Telemetry + IR plane

- **Ingest API:** accepts events from PEPs (OpenTelemetry-compatible traces + domain events).
- **Stores:** Postgres for events + decision logs; optional graph index for fast topology queries.
- **UI:** interaction graph, policy editor, investigations (timeline, replay), export action.

6. Success criteria (V0)

- Within 1-2 weeks of integration, customer identifies at least 1 high-risk shadow AI workflow or data path.
- Customer blocks or constrains at least 1 risky action via policy (not just alerts).
- Customer can produce an evidence bundle for a simulated incident that a security stakeholder accepts.